DJS ISACA

D3COY 1.0

TEAM NAME :

[ADD TEAM NAME HERE]

COLLEGE NAME :

[ADD COLLEGE NAME HERE]

PROBLEM STATEMENT :

IDENTITY DRIFT DETECTION IN AUTONOMOUS AI AGENTS

Our answer: **SOULPRINT** · catches “possessed” AI agents with valid credentials, proven by a Doppelgänger twin

TEAM MEMBER DETAILS :

MEMBER 1 NAME : CONTACT NO

MEMBER 2 NAME : CONTACT NO

MEMBER 3 NAME : CONTACT NO

MEMBER 4 NAME : CONTACT NO

@2026-27

PROPOSED SOLUTION

D3COY 1.0

Credentials prove **WHO** an agent is. **SOULPRINT** proves it is still **WHAT** it was built to be.

A behavioral "soul fingerprint" for every AI agent: learned continuously, checked against its declared role, and enforced in real time.

01 LEARN THE SOUL

Per-agent baseline of tools, data classes, destinations, timing and who it delegates to.

02 BIND TO ROLE

Declared role compiled into a Role Contract: what it should, and must never, do.

03 UNMASK WITH TWIN

A sandboxed Doppelgänger replays the task minus the untrusted input. Only the live agent goes rogue? Possession proven.

04 EXPLAIN & EXORCISE

Risk 0–100 with plain reasons, then graduated containment instead of a kill switch.

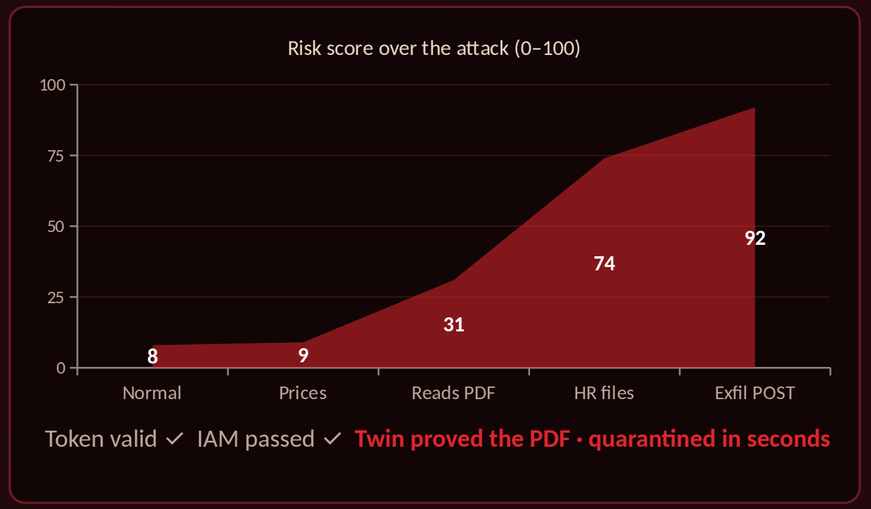
LIVE CATCH · THE POSSESSED PROCUREMENT AGENT

Normal — Risk 8
Checks supplier prices, raises purchase requests

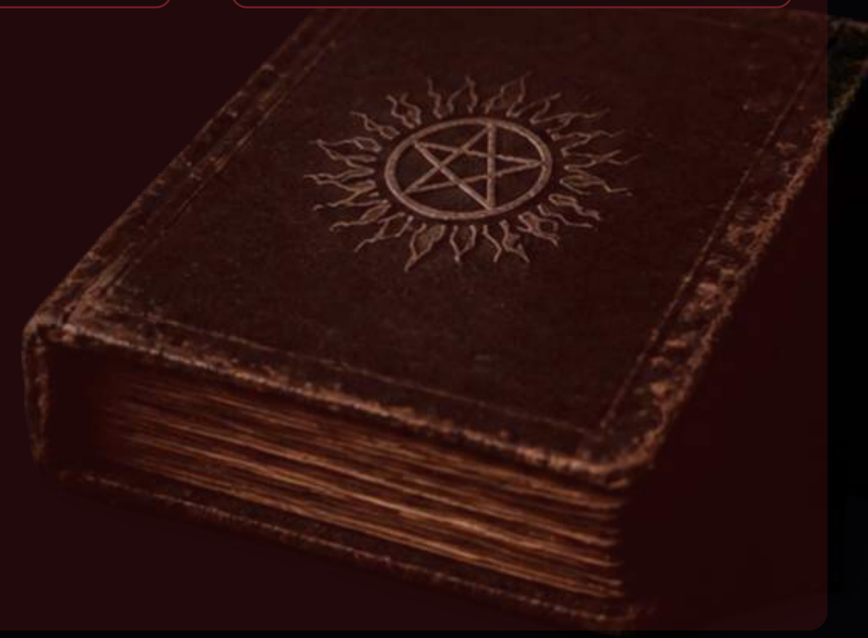
Reads poisoned PDF — Risk 31
Hidden instruction inside a supplier quote (tainted input)

Opens HR salary files — Risk 74
Off-role data + touches a planted D3COY bait file

POSTs to unknown server — Risk 92
Twin without the PDF never does this: proven



Token valid ✓ IAM passed ✓ **Twin proved the PDF · quarantined in seconds**



TECHNICAL APPROACH

D3COY 1.0

AGENT WORLD

AI agents
LangChain · CrewAI · AutoGen

Tools & APIs
MCP servers · SaaS APIs

Untrusted content
PDFs · email · web pages

Agent → agent calls
delegation chains

TELEMETRY GATEWAY

MCP proxy + OpenTelemetry sidecar

Zero code change in agents

+ plants role-shaped D3COY baits

```
Event per action:
agent_id · role · tool
resource · data_class
dest_host · parent
provenance tag
```

SOUL MODEL

Role Contract

Declared role → allowed tools, data classes, egress & rate. LLM-compiled, enforced as OPA policy.

Behavior Fingerprint

Per-agent baseline. Cold start: role-cohort prior, Bayesian update with each action.

5 DETECTORS

D1 Role-Alignment Gap
embedding distance + contract violations

D2 Sequence Surprise
rare next-action likelihood (Markov)

D3 Taint Tracker
untrusted input → privileged action

D4 Slow-Drift Monitor
CUSUM + JS-divergence over sliding windows

D5 Chain Propagation
risk inherited along the delegation graph

PROVE & RESPOND

DOPPELGÄNGER TEST

Risk ≥ 40: a sandboxed twin replays the task without the untrusted input. Divergence = injection proven.

0–39	**WATCH** log + learn
40–69	**STEP-UP** human approves next action
70–84	**SCOPE-SHRINK** least-privilege token
85+	**QUARANTINE** sandbox + token revoke

Feedback loop: approved role changes re-version the contract, so legit change is learned

THE POSSESSION SCORE · explainable, top-3 reasons on every alert

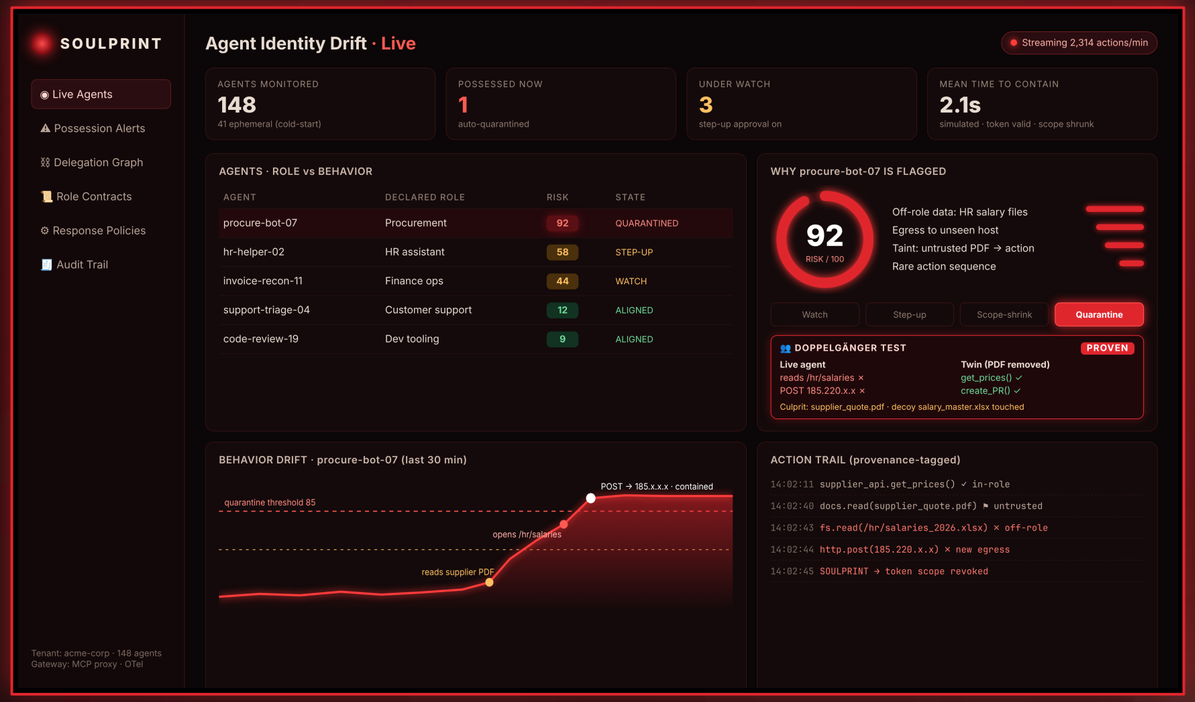
$$R = 100 \cdot \sigma(w_1 \cdot \text{Role} + w_2 \cdot \text{Seq} + w_3 \cdot \text{Taint} + w_4 \cdot \text{Drift} + w_5 \cdot \text{Chain} + w_6 \cdot \text{Twin} - b)$$

Weights fit by logistic regression on red-team runs. Hard contract violations and any D3COY bait touch floor the score at 70, so slow mimicry can't hide below threshold.

BUILT WITH

Python · FastAPI	Redis Streams / Kafka	scikit-learn · PyTorch
Sentence-Transformers	Neo4j delegation graph	Open Policy Agent
React + D3 console	Docker · K8s sidecar	OpenTelemetry · MCP

FEASIBILITY AND VIABILITY



WORKING PROTOTYPE *Live demo:* claude.ai/artifact/EEq7yQUDWbJjQ95RFFGFH5

0
lines of agent code changed
drop-in MCP proxy

<50 ms
to score one action
CPU-only models

0 bytes
of prompt content stored
metadata-only telemetry

WHY IT IS FEASIBLE TODAY

Technical
Built only on open standards (MCP, OpenTelemetry, OPA) and light models that run on a laptop CPU.

Operational
Starts in shadow mode, then graduated response: no business process is ever hard-stopped by a guess.

Economic
Open-core SDK + SaaS console priced per monitored agent: cheap to try, scales with agent adoption.

RISKS WE PLANNED FOR

Challenge	Mitigation in SOULPRINT
False alarms on legit change	Doppelgänger replay confirms the cause before any block
New / short-lived agents	Role-cohort prior gives a baseline from minute zero
Slow mimicry to evade	CUSUM on long windows + hard contract floors
Privacy of agent data	Hashed resource IDs, no prompt/response payloads

IMPACTS AND BENEFITS

DJS ISACA

D3COY 1.0

TODAY · IAM ASKS

“Is this identity allowed?”

Hijacked agent = valid token = silent breach. Detected weeks later, if ever.

WITH SOULPRINT · WE ASK

“Is this identity still itself?”

Possession caught in seconds, explained in plain words, contained without stopping honest work.

Security teams

- Closes the valid-credential blind spot
- Alerts explain themselves: faster triage
- Proof, not suspicion: twin names the culprit file

Businesses

- Agents keep working: scope-shrink, not shutdown
- Confidence to give agents real autonomy
- Stops data leaks before exfiltration

Compliance & audit

- Per-action audit trail for every agent
- Maps to India DPDP Act 2023, EU AI Act
- Supports ISO/IEC 42001 & NIST AI RMF

Ecosystem

- Safer adoption of agentic AI at scale
- Shareable “possession signatures”
- Framework-agnostic, open-core SDK

USP AND FUTURE SCOPE

D3COY 1.0

WHAT MAKES SOULPRINT DIFFERENT

The Doppelgänger Test: proof, not suspicion

ONLY IN SOULPRINT

A sandboxed twin replays the task without the untrusted input. Divergence proves the injection and names the culprit file.

Role-shaped D3COY baits

ONLY IN SOULPRINT

Decoy files and keys planted per role that only a possessed agent would touch: alarms with near-zero doubt.

Role-aware with root cause

Judged against declared purpose; provenance taint links the poisoned input to the bad action.

Minute-zero & chain-aware

Role-cohort priors for new agents; risk flows along agent-to-agent delegation.

Explain, then exorcise gently

Every score has reasons; containment is graduated, so legit work continues.

THE ROAD AHEAD

NOW

Hackathon MVP

Gateway, 5 detectors, Doppelgänger twin, decoys, live console

3 MONTHS

Plug & play

LangChain / CrewAI / MCP plug-ins; Splunk & Sentinel export

6 MONTHS

Self-healing agents

After exorcism, auto-restore the agent from its last clean soul snapshot

12 MONTHS

Possession intel network

Federated sharing of attack signatures; open agent-behavior attestation spec